VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Deathnote CTF — Authorized Lab Assessment

Target hostname	deathnote.lan / deathnote.vuln
Victim IP	192.168.31.43
Platform	Kali Linux — isolated CTF lab
Assessment date	14 October 2026
Scope	Victim machine only

Additional discovered hostnames and IP addresses are redacted from evidence where identified. Only the victim identity is retained.

1. Executive Summary

The supplied evidence documents an assessment of the intentionally vulnerable Deathnote CTF target at **192.168.31.43** (deathnote.lan / deathnote.vuln). Enumeration confirmed SSH on TCP/22 and HTTP on TCP/80. Web investigation found a WordPress site, a robots.txt hint pointing to an image, and an encoded clue that disclosed credentials for local user **kira**. The evidence then shows successful SSH access as kira and a sudo configuration allowing root-level command execution.

The spreadsheet lists FTP/vsftpd 2.3.4 on port 21 as Critical. However, the supplied Nmap service scan shows only ports 22 and 80 open and reports 65,533 closed TCP ports. FTP is therefore **not validated** and is documented as an evidence discrepancy, not a confirmed vulnerability.

2. Scope and Methodology

Scope: victim 192.168.31.43 only. Activities evidenced include Nmap discovery/service detection, web-source inspection, directory enumeration, robots.txt review, decoding Brainfuck and Base64 clues, SSH authentication, and sudo privilege review.

Tools: Nmap, Dirsearch, browser/source view, CyberChef, Brainfuck interpreter, SSH, and Linux utilities (id, whoami, ls, cat, sudo).

3. Attack Surface Summary

Port	Observed service	Assessment
22/tcp	OpenSSH 7.9p1 Debian 10+deb10u2	SSH exposure confirmed; access was credential-based, not an SSH daemon exploit.
80/tcp	Apache 2.4.38 (Debian); WordPress 5.8 metadata	Web service and public content paths confirmed; clues assisted credential discovery.
21/tcp	FTP/vsftpd 2.3.4 listed in spreadsheet only	Unverified; not shown open in the supplied Nmap service scan.

4. Findings and Proof of Concept

Finding 1 — Exposed HTTP service and technology disclosure

Port: 80/tcp | **Severity:** Informational/Low | **CVE:** N/A

Observation: Nmap identified Apache httpd 2.4.38 (Debian). Page source showed WordPress 5.8 metadata and common WordPress paths. Version disclosure helps identify components for patch review but does not, by itself, prove a specific exploitable CVE.

PoC: (1) Run `nmap -sV -p- 192.168.31.43` in the lab. (2) Browse to the configured WordPress path. (3) View page source and observe generator metadata and asset paths. (4) Validate versions against vendor advisories before claiming exploitability.

Remediation: Patch Apache, WordPress, themes and plugins; remove unused components and unnecessary version disclosure.

Finding 2 — Web content discovery and robots.txt information disclosure

Port: 80/tcp | **Severity:** Low | **CVE:** N/A

Observation: Dirsearch discovered paths including `/wordpress/`, `/wordpress/wp-login.php`, `/robots.txt` and `/manual/`. robots.txt referenced `/important.jpg`, which contained a clue pointing toward user.txt and the site's hint section.

PoC: Run `dirsearch -u http://deathnote.vuln/`, request `http://deathnote.vuln/robots.txt`, then review the referenced clue file in the authorized lab.

Remediation: Do not store secrets or credential hints in public files. Protect sensitive content with server-side authorization; robots.txt is public.

Finding 3 — Encoded clue exposed a user credential

Severity: High in the lab context | **CVE:** N/A

Observation: The clue chain used a Brainfuck-encoded message and encoded text decoded with CyberChef. The evidence shows the recovered lab password for user **kira** as **kiraisevil**. Encoding is not encryption; credential material should not be retrievable from public content.

PoC: Decode the Brainfuck clue with an interpreter, inspect the indicated hint files, and use CyberChef to decode the provided hex/Base64 content. Validate the recovered credential only against the authorized CTF target.

Remediation: Remove credential material from web-accessible content, rotate exposed passwords, and use unique strong credentials or SSH keys.

Finding 4 — SSH access using recovered credentials

Port: 22/tcp | **Severity:** High given credential exposure | **CVE:** N/A

Observation: SSH login as **kira** succeeded; terminal evidence confirms the user with id and whoami. This is credential-based access, not proof of an OpenSSH software exploit.

PoC: In the lab, connect with `ssh kira@192.168.31.43`, authenticate using the recovered lab credential, then run `id` and `whoami`.

Remediation: Rotate the exposed password, prefer SSH keys where feasible, restrict SSH access and monitor authentication logs.

Finding 5 — Unrestricted sudo permissions enabled root access

Severity: Critical | **CVE:** N/A

Observation: The screenshot shows sudo permissions allowing kira to run commands as root (ALL:ALL ALL), followed by `sudo su` and `whoami` returning root. This is a direct privilege-escalation path due to excessive sudo rights.

PoC: After logging in as kira, run `sudo -l` and inspect the permitted command specification. The evidence then shows `sudo su` and root identity.

Remediation: Remove unrestricted sudo rules, allow only required commands, review sudoers with visudo, and audit privileged group membership.

Finding 6 — FTP/vsftpd 2.3.4 claim requires validation

Port: 21/tcp | **Severity:** Unconfirmed | **CVE:** Not established from supplied evidence

Observation: report1(3).xlsx lists FTP/vsftpd 2.3.4 as Critical, but the Nmap screenshot lists only ports 22 and 80 open. No FTP banner or port-21 connection is visible, so no FTP exploit is asserted.

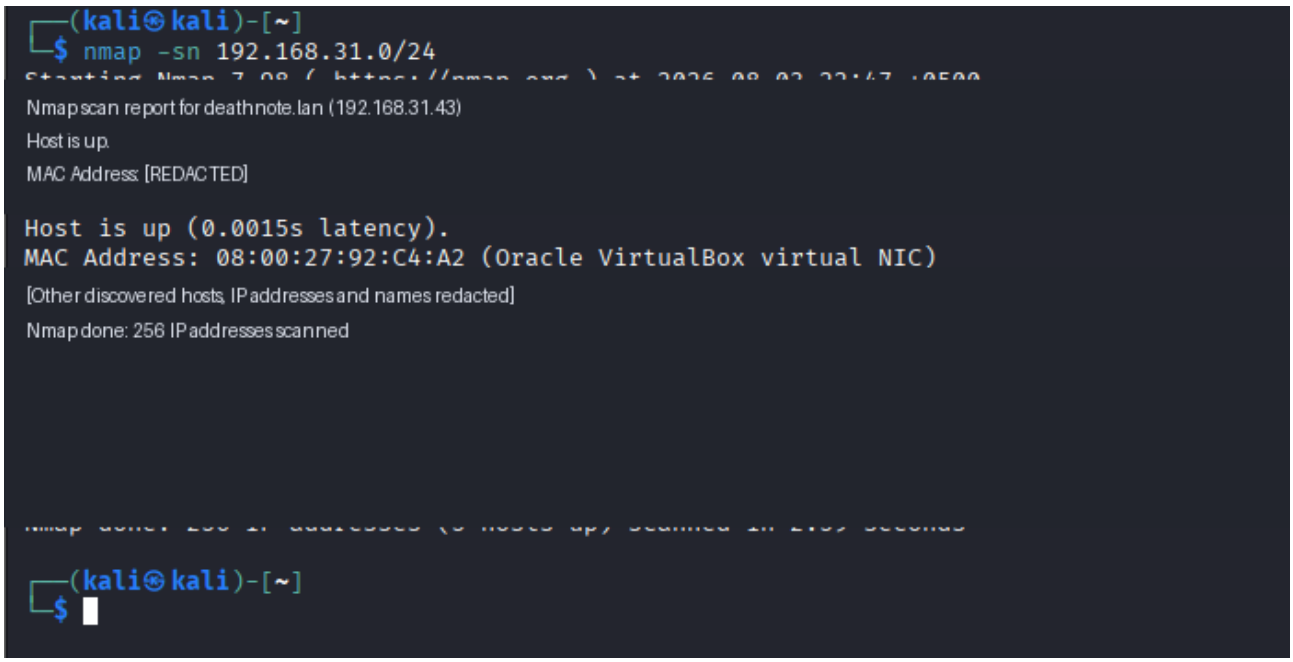
Validation PoC: Run `nmap -sV -p 21 192.168.31.43` in the lab. Only document a vulnerability after confirming that port 21 is open and independently verifying the service/version.

Remediation if confirmed: Disable FTP if unnecessary; otherwise upgrade to a supported version, restrict access, and verify patch status.

5. Screenshot Evidence Appendix

Screenshots are included as supporting evidence. The network-discovery image and SSH previous-login line have been redacted to remove non-victim host details.

01 — Nmap discovery (other hosts redacted)



Evidence supplied by user; redactions applied where noted.

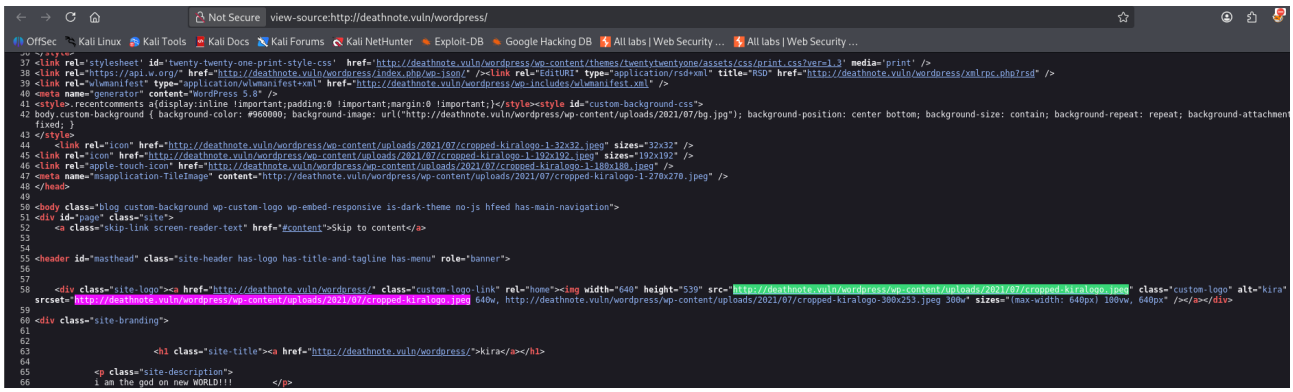
02 — Nmap service/version scan

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 192.168.31.43
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-03 22:48 +0500
Nmap scan report for deathnote.lan (192.168.31.43)
Host is up (0.0014s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.38 ((Debian))
MAC Address: 08:00:27:92:C4:A2 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.04 seconds
```

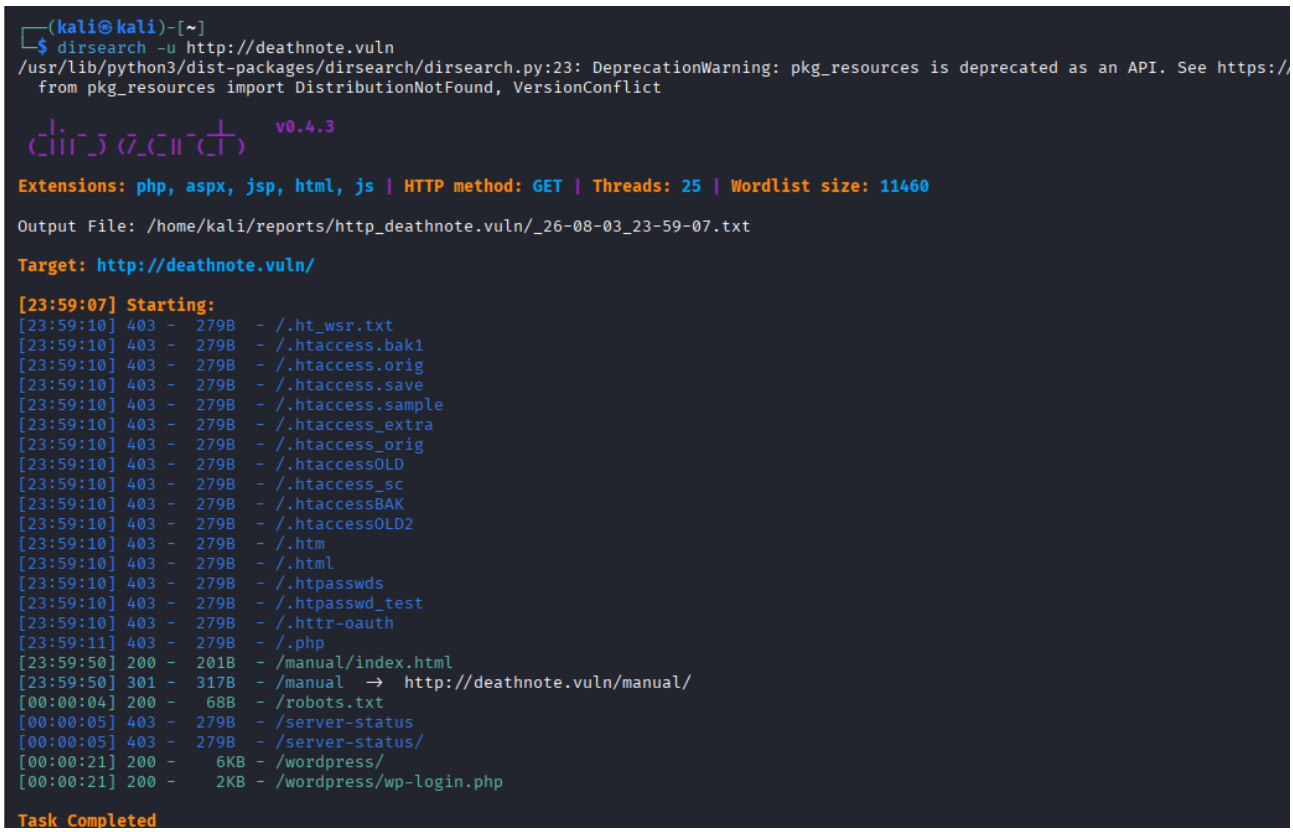
Evidence supplied by user; redactions applied where noted.

03 — WordPress source and metadata



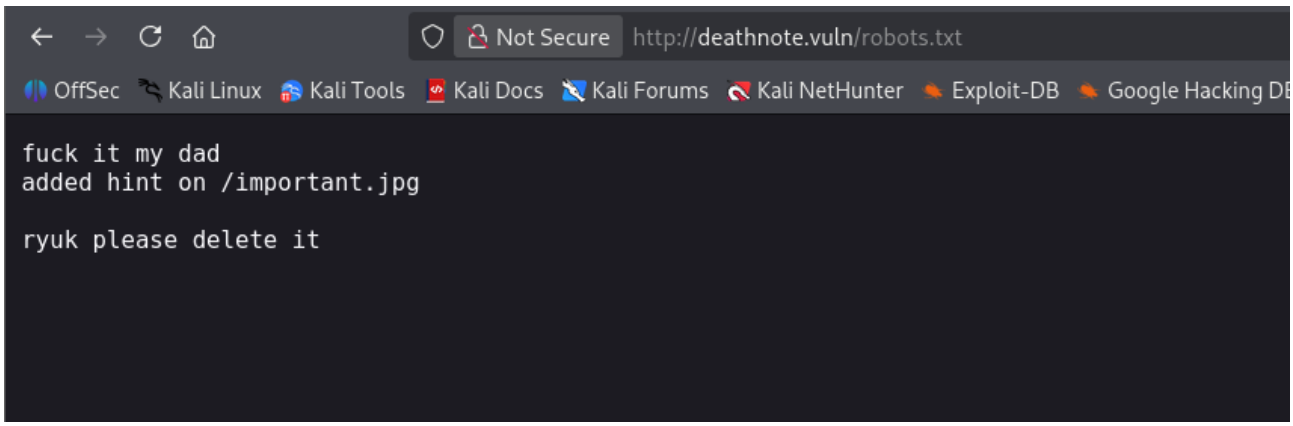
Evidence supplied by user; redactions applied where noted.

04 — Dirsearch results



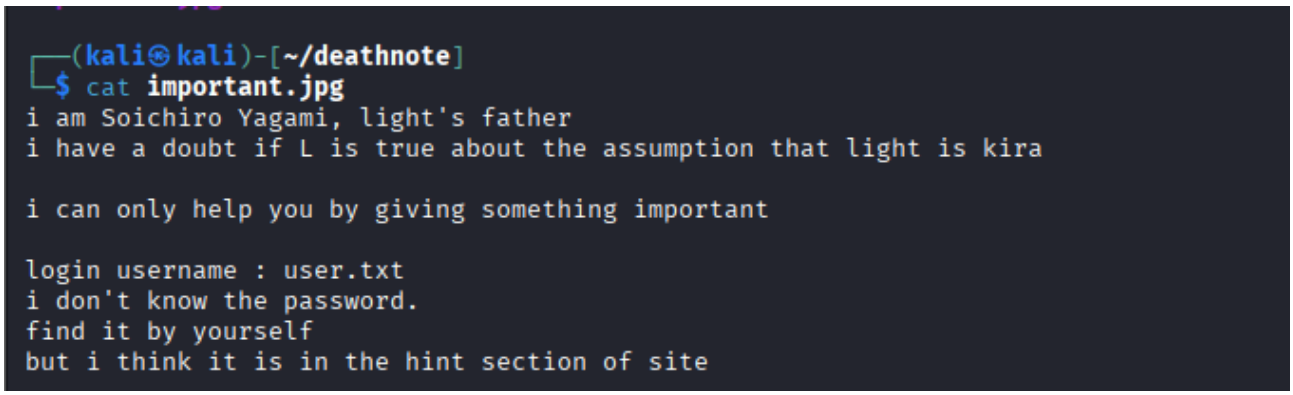
Evidence supplied by user; redactions applied where noted.

05 — robots.txt clue



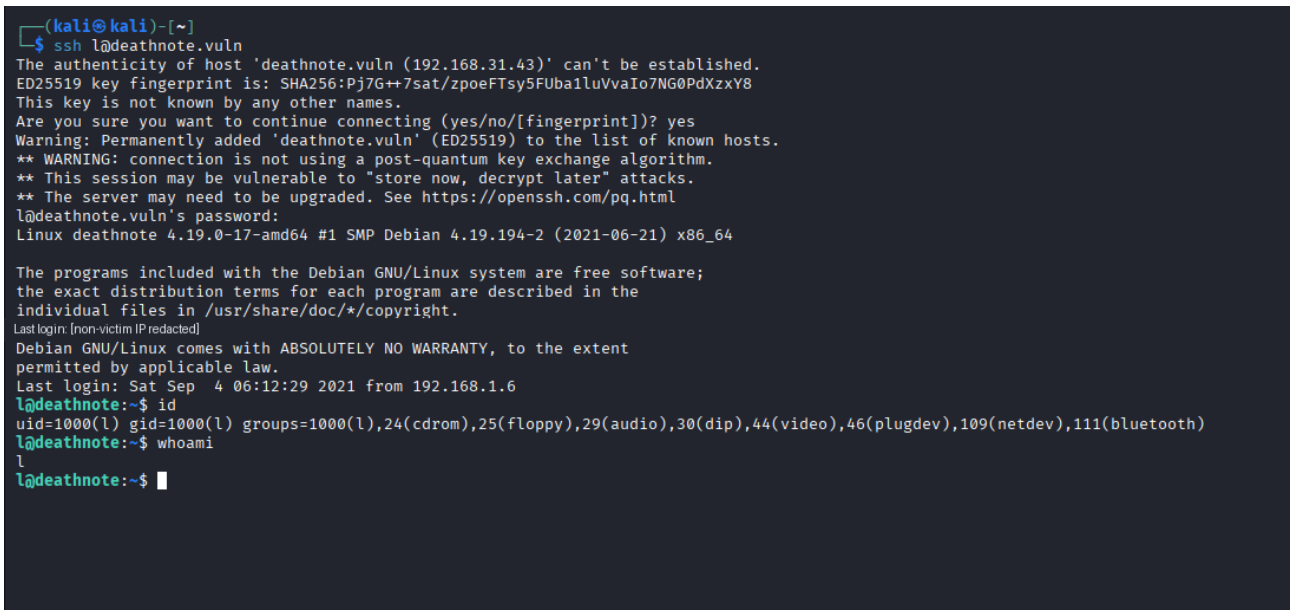
Evidence supplied by user; redactions applied where noted.

06 — important.jpg clue



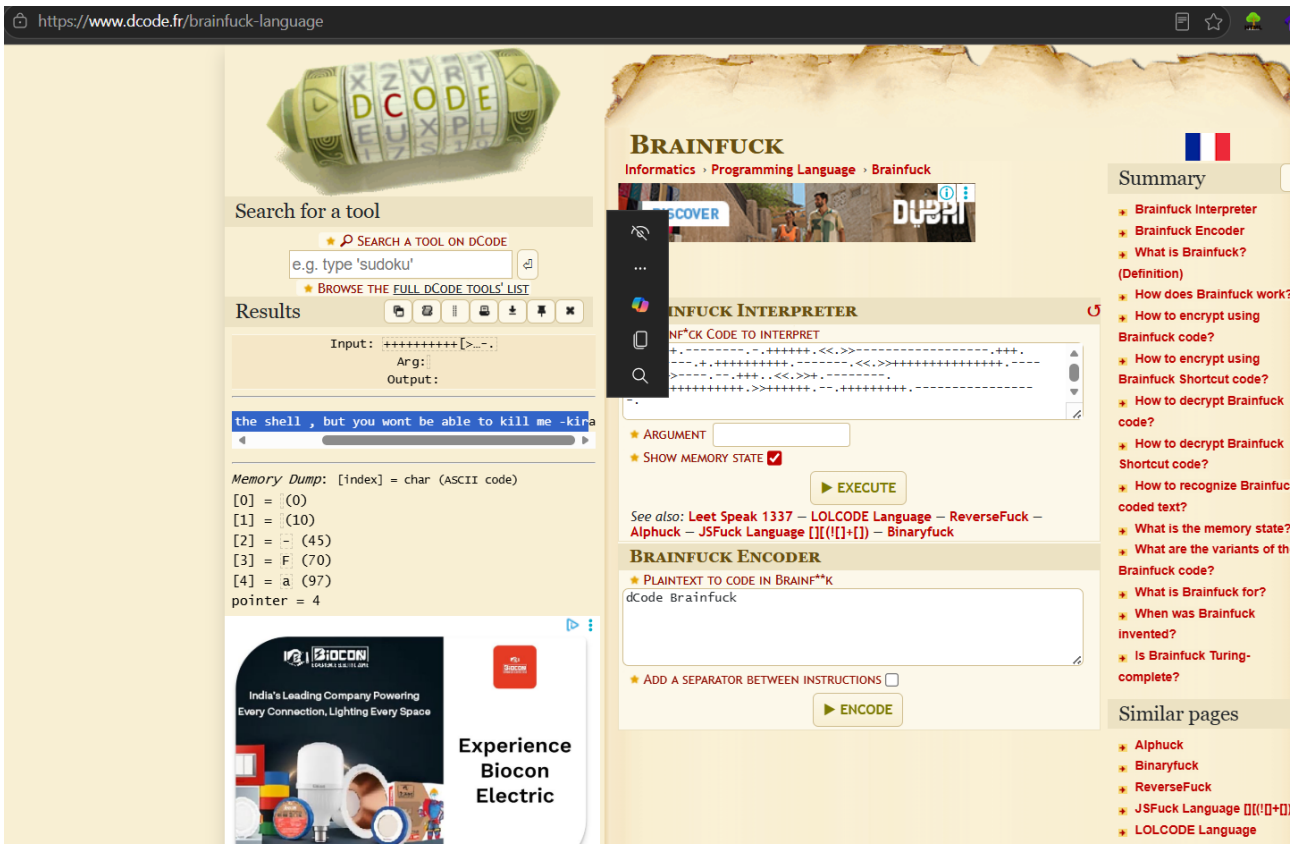
Evidence supplied by user; redactions applied where noted.

07 — SSH session (previous-login IP redacted)



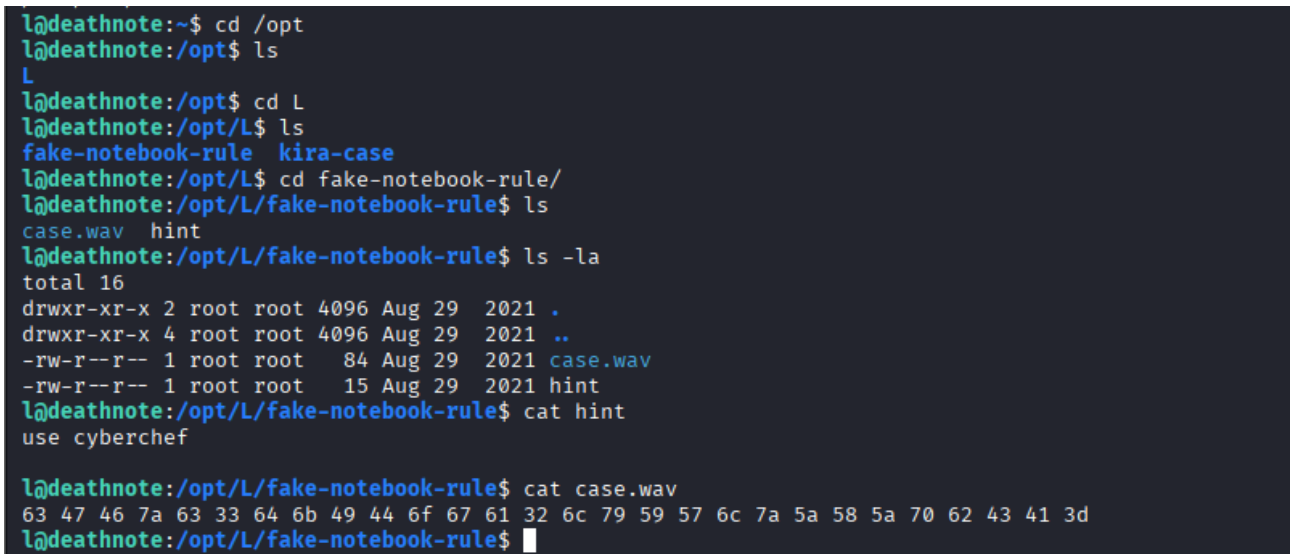
Evidence supplied by user; redactions applied where noted.

08 — Brainfuck interpreter



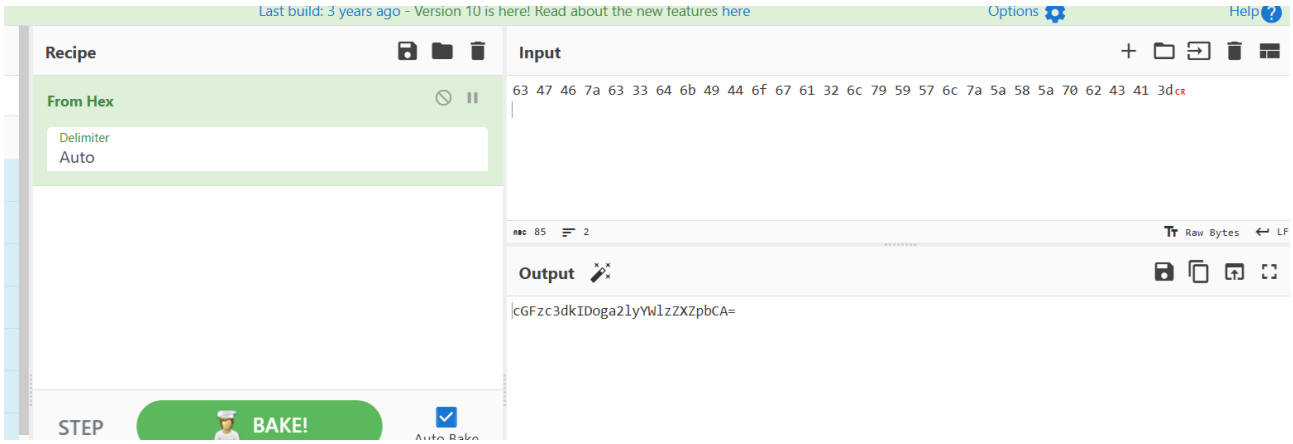
Evidence supplied by user; redactions applied where noted.

09 — Hex decoding workflow



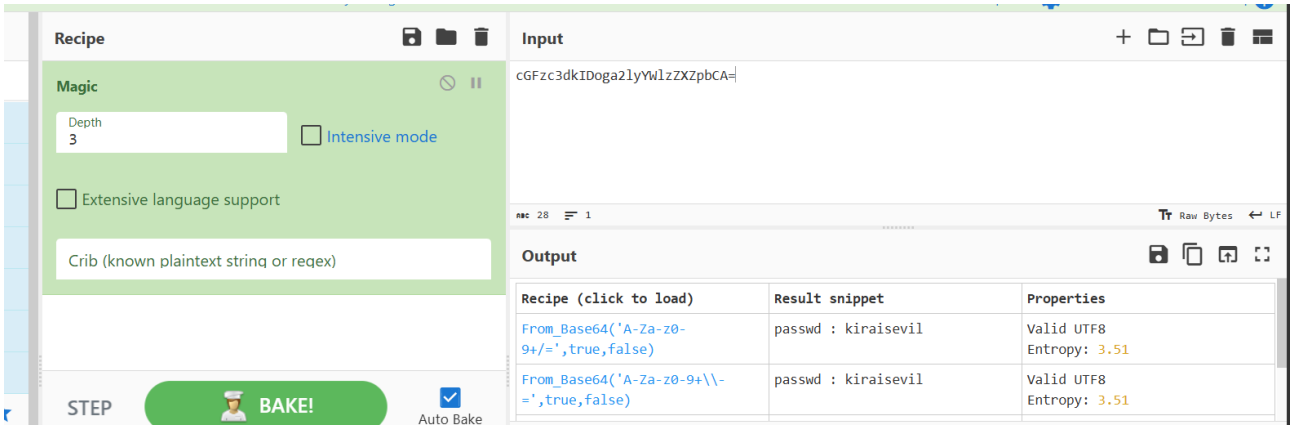
Evidence supplied by user; redactions applied where noted.

10 — CyberChef Base64 decode result



Evidence supplied by user; redactions applied where noted.

11 — Decoding result



Evidence supplied by user; redactions applied where noted.

12 — User kira shell

```
l@deathnote:/opt/L/kira-case$ su kira
Password:
kira@deathnote:/opt/L/kira-case$ ls
case-file.txt
kira@deathnote:/opt/L/kira-case$ id
uid=1001(kira) gid=1001(kira) groups=1001(kira),27(sudo)
kira@deathnote:/opt/L/kira-case$ whoami
kira
kira@deathnote:/opt/L/kira-case$
```

Evidence supplied by user; redactions applied where noted.

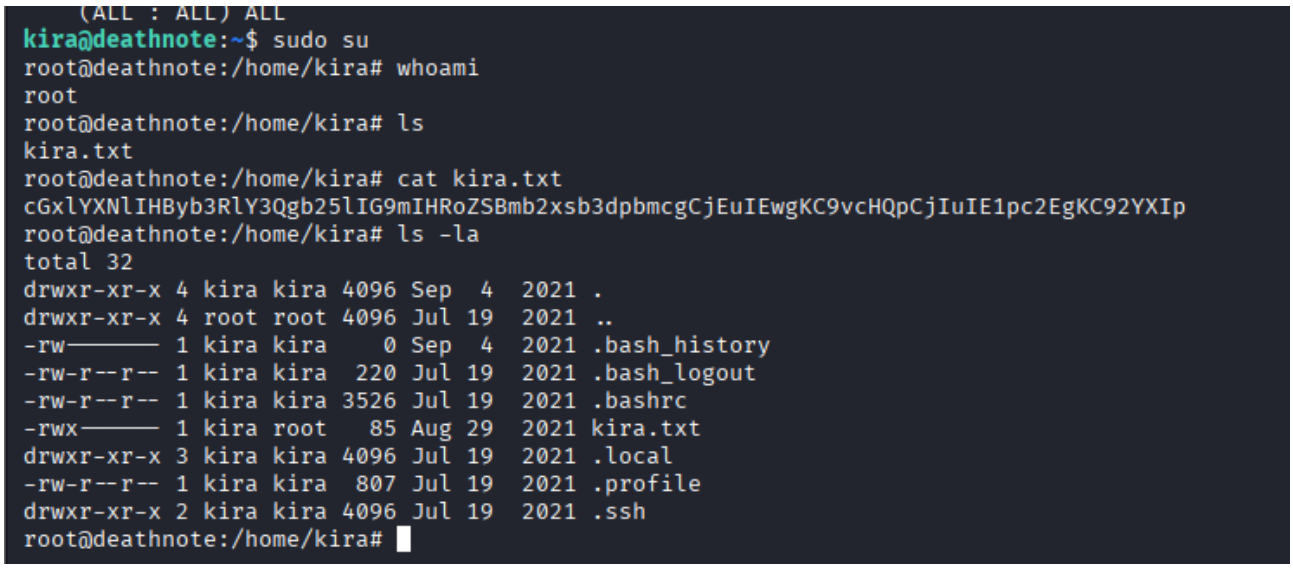
13 — sudo permissions and root shell

```
and we also found something in
fake-notebook-rule folder .
l@deathnote:/opt/L/kira-case$ su kira
Password:
kira@deathnote:/opt/L/kira-case$ ls
case-file.txt
kira@deathnote:/opt/L/kira-case$ id
uid=1001(kira) gid=1001(kira) groups=1001(kira),27(sudo)
kira@deathnote:/opt/L/kira-case$ whoami
kira
kira@deathnote:/opt/L/kira-case$ cd /home/kira
kira@deathnote:~$ ls
kira.txt
kira@deathnote:~$ cat kira.txt
cGxlYXNlIHByb3RlY3Qgb25lIG9mIHRoZSBmb2xsb3dpbmcgCjEuIEwgKC9vcHQpCjIuIE1pc2EgKC92YXIp
kira@deathnote:~$ sudo -l
[sudo] password for kira:
Sorry, try again.
[sudo] password for kira:
Matching Defaults entries for kira on deathnote:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User kira may run the following commands on deathnote:
    (ALL : ALL) ALL
kira@deathnote:~$ sudo su
root@deathnote:/home/kira# whoami
root
root@deathnote:/home/kira#
```

Evidence supplied by user; redactions applied where noted.

14 — root identity evidence



Evidence supplied by user; redactions applied where noted.

15 — encoded hint

```
root@deathnote:/home/kira# echo "cGxlYXNlIHByb3RlY3Qgb25lIG9mIHRoZSBmb2xsb3dpbmcgCjEuIEwgKC9vcHQpCjIuIE1pc2EgKC92YXIp"|base64 -d
please protect one of the following
1. L (/opt)
2. Misa (/var)root@deathnote:/home/kira#
```

Evidence supplied by user; redactions applied where noted.

16 — root file-system clue

```
root@deathnote:/var# ls
backups  cache  lib  local  lock  log  mail  misa  opt  run  spool  tmp  www
root@deathnote:/var# find Misa
find: ‘Misa’: No such file or directory
root@deathnote:/var# cd www
root@deathnote:/var/www# ls
deathnote.vuln  html
root@deathnote:/var/www# cd ..
root@deathnote:/var# ls
backups  cache  lib  local  lock  log  mail  misa  opt  run  spool  tmp  www
root@deathnote:/var# cd misa
bash: cd: misa: Not a directory
root@deathnote:/var# ls -la
total 52
drwxr-xr-x 12 root root  4096 Aug 29  2021 .
drwxr-xr-x 18 root root  4096 Jul 19  2021 ..
drwxr-xr-x  2 root root  4096 Sep  4  2021 backups
drwxr-xr-x 11 root root  4096 Jul 19  2021 cache
drwxr-xr-x 29 root root  4096 Jul 19  2021 lib
drwxrwsr-x  2 root staff 4096 Jun 13  2021 local
lrwxrwxrwx  1 root root     9 Jul 19  2021 lock → /run/lock
drwxr-xr-x  7 root root  4096 Sep  4  2021 log
drwxrwsr-x  2 root mail  4096 Jul 19  2021 mail
-rw-r--r--  1 root root    27 Aug 29  2021 misa
drwxr-xr-x  2 root root  4096 Jul 19  2021 opt
lrwxrwxrwx  1 root root     4 Jul 19  2021 run → /run
drwxr-xr-x  5 root root  4096 Jul 19  2021 spool
drwxrwxrwt  4 root root  4096 Aug  3 15:39 tmp
drwxr-xr-x  4 root root  4096 Sep  4  2021 www
root@deathnote:/var# cat misa
it is toooo late for misa
```

Evidence supplied by user; redactions applied where noted.

6. Risk Summary and Remediation Priorities

Critical: Remove unrestricted sudo permissions for kira and verify least privilege.

High: Remove the exposed credential clue, rotate the recovered password, and review SSH logs.

Low/Informational: Remove unnecessary public files and patch the web stack.

Evidence gap: Validate the spreadsheet's FTP claim before documenting port 21 as open or vulnerable.

7. Conclusion

The evidence supports this lab attack path: web content discovery → clue decoding → recovery of kira's credential → SSH login → unrestricted sudo → root shell. The strongest confirmed finding is excessive sudo privilege, while credential exposure enabled initial access. Unverified spreadsheet entries are clearly separated from confirmed observations.

Disclaimer: This report is for educational use in an intentionally vulnerable CTF lab. Do not test systems without explicit permission.

DEATHNOTE CTF — DETAILED PROOF OF CONCEPT

Evidence-led, step-by-step reproduction notes for the confirmed lab attack path. This section is part of the VAPT report and follows the practical PoC style of the supplied Kioptrix sample.

Target: deathnote.lan / deathnote.vuln **Victim IP:** 192.168.31.43

Scope note: Execute only against the intentionally vulnerable CTF target. Commands below are limited to the lab host. Other discovered hosts are outside scope and redacted.

PoC 1 — Host discovery and victim identification

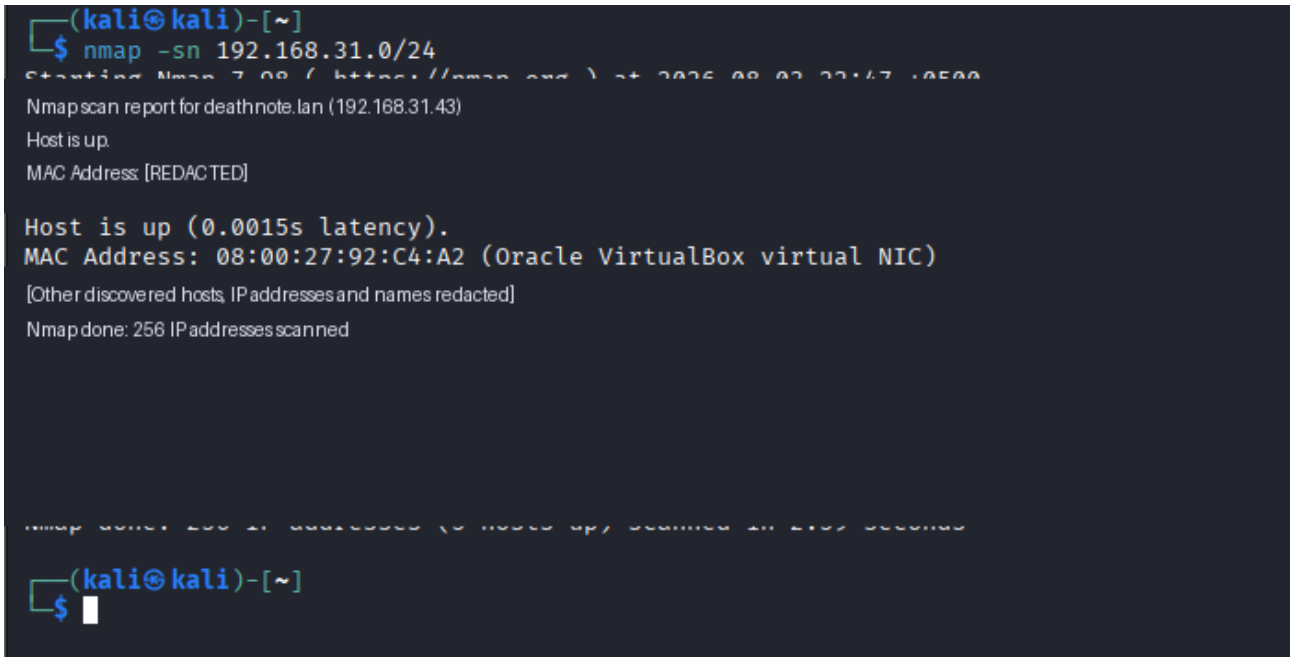
Objective: Identify the target on the lab subnet and retain only the victim record in the report.

Command:

```
nmap -sn 192.168.31.0/24
```

Observed result: The supplied discovery screenshot identifies **deathnote.lan (192.168.31.43)** as up. Other host records and addresses are redacted in the evidence copy.

Validation: Confirm that the discovered hostname/IP matches the assigned CTF machine before continuing. Do not test the other discovered hosts.



Evidence 1. Nmap host discovery with non-victim host information redacted.

PoC 2 — TCP port and service/version enumeration

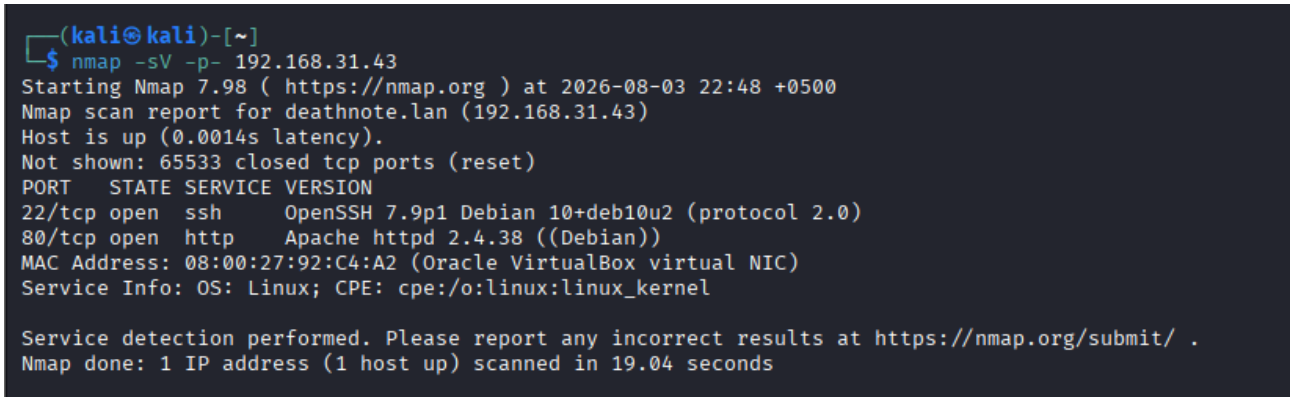
Objective: Identify the exposed services on the victim and establish a baseline attack surface.

Command shown in evidence:

```
nmap -sV -p- 192.168.31.43
```

Observed result: The screenshot reports TCP/22 open running OpenSSH 7.9p1 Debian 10+deb10u2 and TCP/80 open running Apache httpd 2.4.38 (Debian). The scan reports the other TCP ports closed.

Finding: SSH and HTTP are exposed. The screenshot does not validate FTP on port 21; the spreadsheet entry for vsftpd 2.3.4 must be retested before it is reported as a confirmed vulnerability.



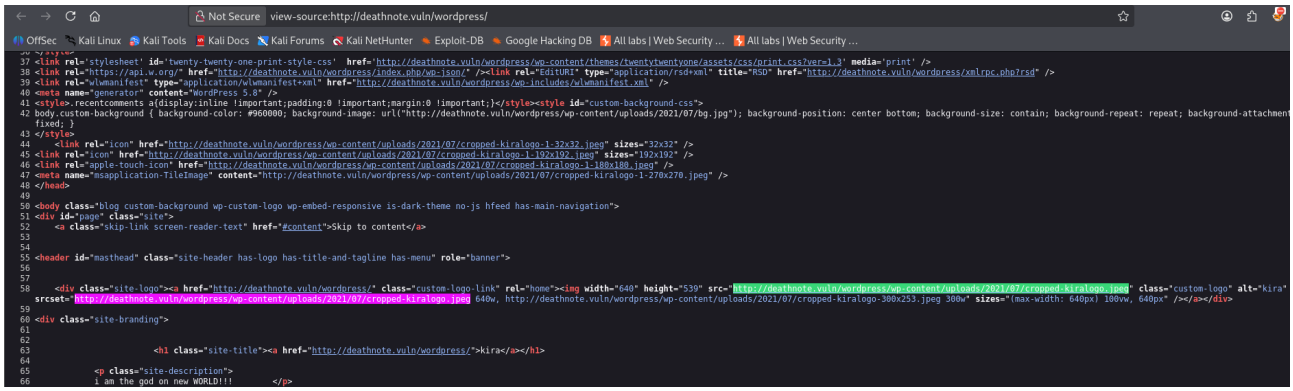
Evidence 2. Nmap service/version detection against the victim.

PoC 3 — WordPress source and version disclosure

Objective: Review the web application's public metadata and identify its platform.

Steps: (1) Open the target's WordPress path in the browser. (2) View page source. (3) Locate generator metadata and WordPress asset paths. (4) Record the observed version and verify it against trusted vendor advisories before assigning a CVE.

Observed result: The supplied source screenshot shows WordPress 5.8 metadata and WordPress theme/plugin asset paths. This is version disclosure and technology fingerprinting; the screenshot alone does not prove a specific WordPress exploit.



Evidence 3. WordPress page source and public metadata.

PoC 4 — Web directory enumeration

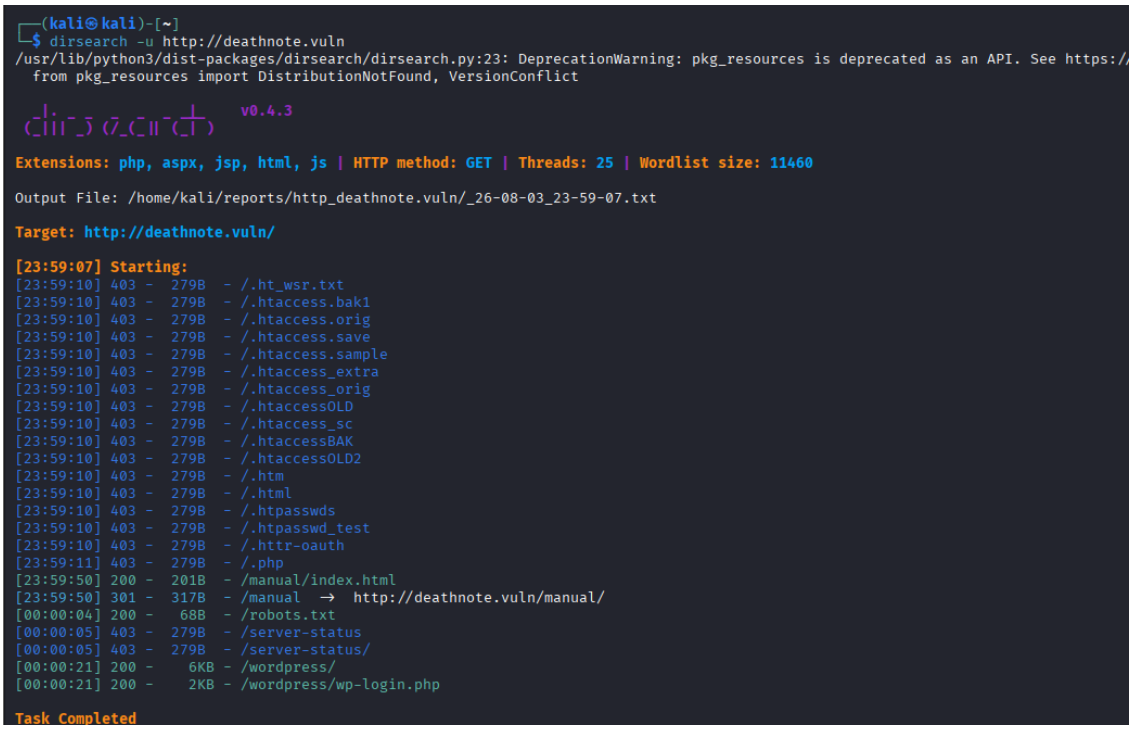
Objective: Identify publicly reachable paths that may contain useful information.

Command:

```
dirsearch -u http://deathnote.vuln
```

Observed result: Dirsearch returned paths including `/robots.txt`, `/wordpress/`, `/wordpress/wp-login.php` and `/manual/`. Several requests returned 403, which indicates access was forbidden for those paths, not that the files were successfully accessed.

Security impact: Public path enumeration can reveal application structure. Directory discovery alone is not proof of a vulnerability; the content exposed at the paths determines the risk.



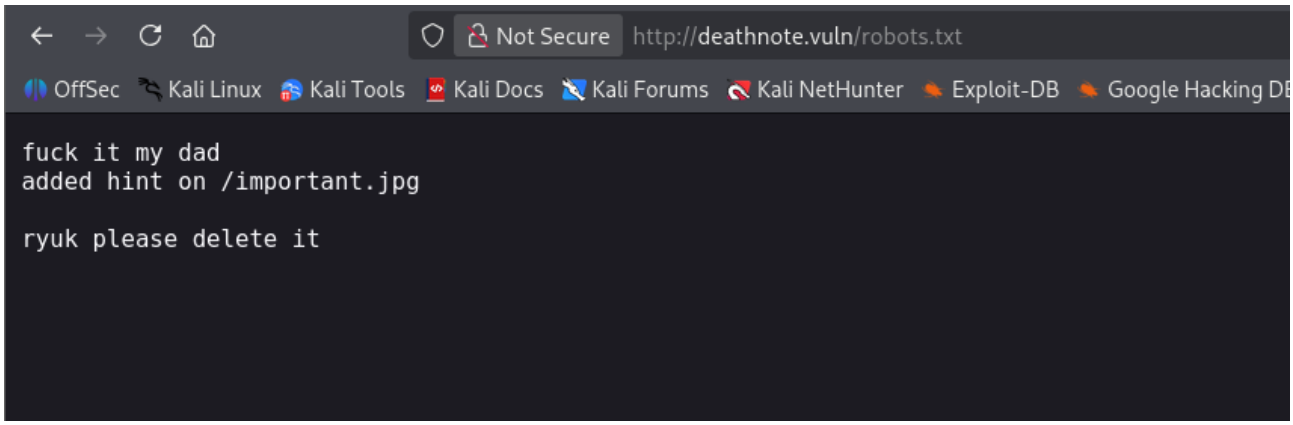
Evidence 4. Dirsearch output from the lab target.

PoC 5 — robots.txt clue and exposed image

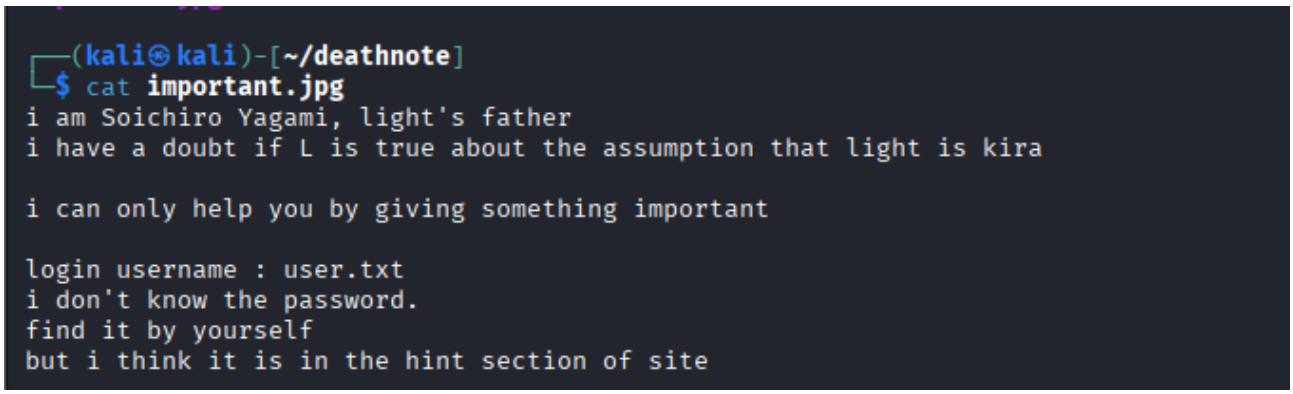
Objective: Follow the publicly exposed hint discovered during web enumeration.

Steps: (1) Request `http://deathnote.vuln/robots.txt`. (2) Observe the reference to `/important.jpg`. (3) Open the referenced file in the browser or download it in the lab. (4) Read the clue contained in the image/text.

Observed result: The robots.txt screenshot contains a hint to `/important.jpg`. The image clue states that the user login name is in `user.txt` and directs the tester to the website's hint section. robots.txt is publicly readable and should never be used to protect secrets.



Evidence 5. robots.txt clue.



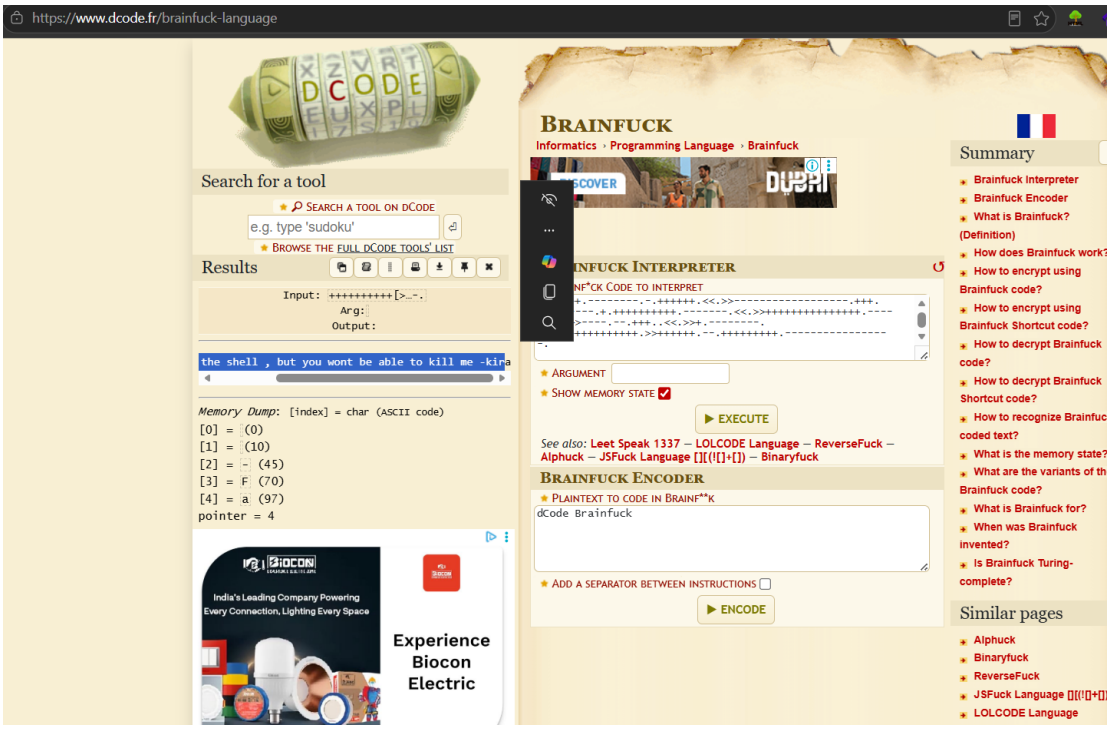
Evidence 6. Clue recovered from important.jpg.

PoC 6 — Decode the challenge clue

Objective: Decode the challenge's intentionally encoded message and retrieve the lab user credential clue.

Steps: (1) Use a Brainfuck interpreter on the code shown in the clue. (2) Follow the output to the fake-notebook hint directory. (3) Inspect the hint and the supplied case.wav hex string. (4) Convert the hex bytes to text, then try Base64 decoding in CyberChef as shown in the screenshots. (5) Validate the decoded result only on the authorized CTF target.

Observed result: The supplied CyberChef output identifies a password clue for the local user **kira**; the subsequent SSH screenshot confirms the account login succeeded. Encoding is not encryption, and storing passwords in encoded form is unsafe.



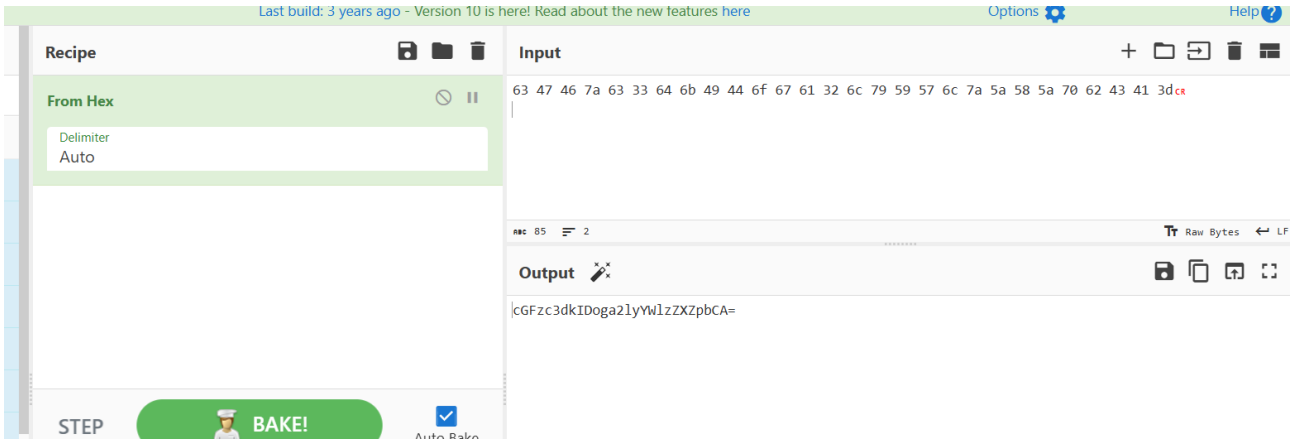
Evidence 7. Brainfuck interpreter output.

```
l@deathnote:~$ cd /opt
l@deathnote:/opt$ ls
L
l@deathnote:/opt$ cd L
l@deathnote:/opt/L$ ls
fake-notebook-rule  kira-case
l@deathnote:/opt/L$ cd fake-notebook-rule/
l@deathnote:/opt/L/fake-notebook-rule$ ls
case.wav  hint
l@deathnote:/opt/L/fake-notebook-rule$ ls -la
total 16
drwxr-xr-x 2 root root 4096 Aug 29  2021 .
drwxr-xr-x 4 root root 4096 Aug 29  2021 ..
-rw-r--r-- 1 root root   84 Aug 29  2021 case.wav
-rw-r--r-- 1 root root   15 Aug 29  2021 hint
l@deathnote:/opt/L/fake-notebook-rule$ cat hint
use cyberchef

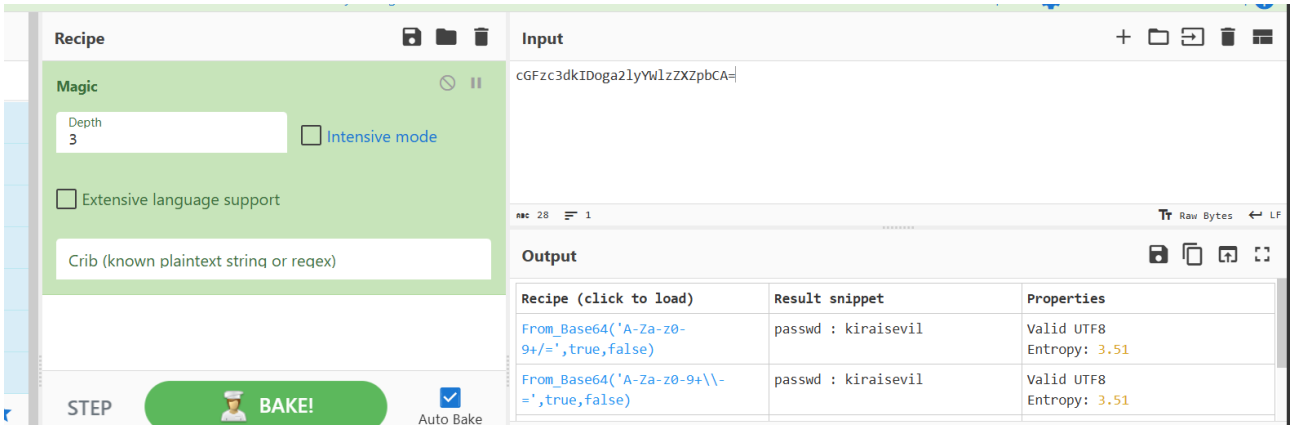
l@deathnote:/opt/L/fake-notebook-rule$ cat case.wav
63 47 46 7a 63 33 64 6b 49 44 6f 67 61 32 6c 79 59 57 6c 7a 5a 58 5a 70 62 43 41 3d
l@deathnote:/opt/L/fake-notebook-rule$
```

Evidence 8. Hex-to-text decoding stage.

PoC 6 — Decode the challenge clue (continued)



Evidence 9. CyberChef Base64 decode recipe/result.



Evidence 10. Decoded clue result.

Security impact: The public clue chain exposed a credential that enabled access to the victim over SSH. Remove such clues and rotate any exposed credential in real systems.

PoC 7 — SSH authentication as kira

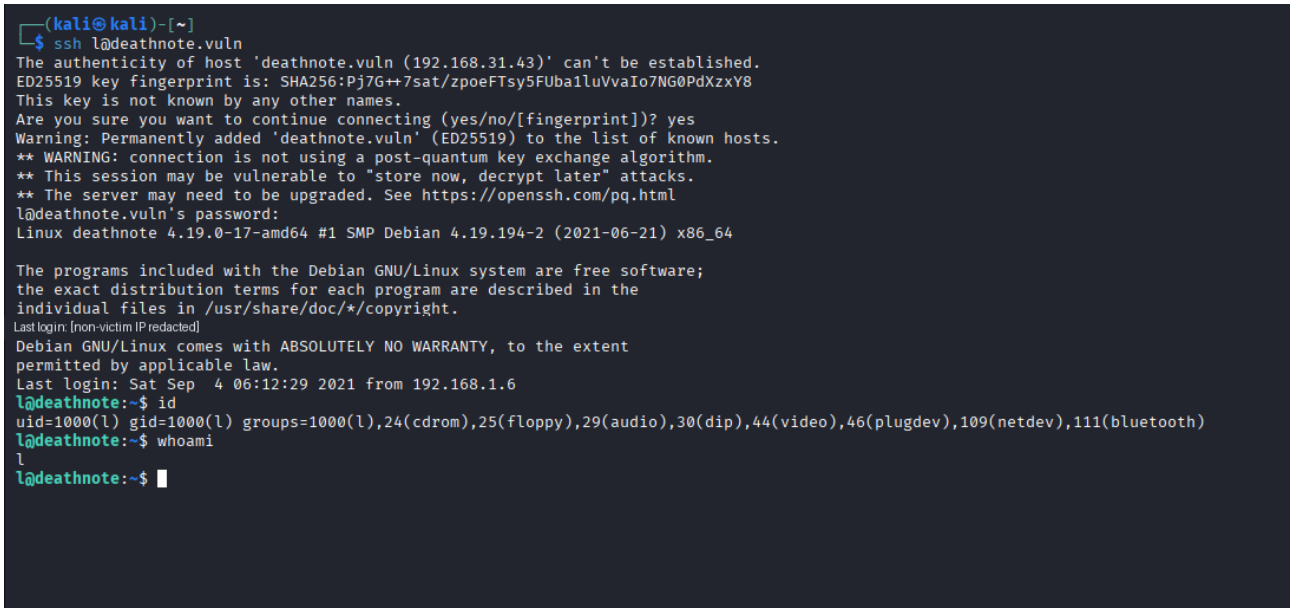
Objective: Verify whether the recovered lab credential grants access to the victim's SSH service.

Command:

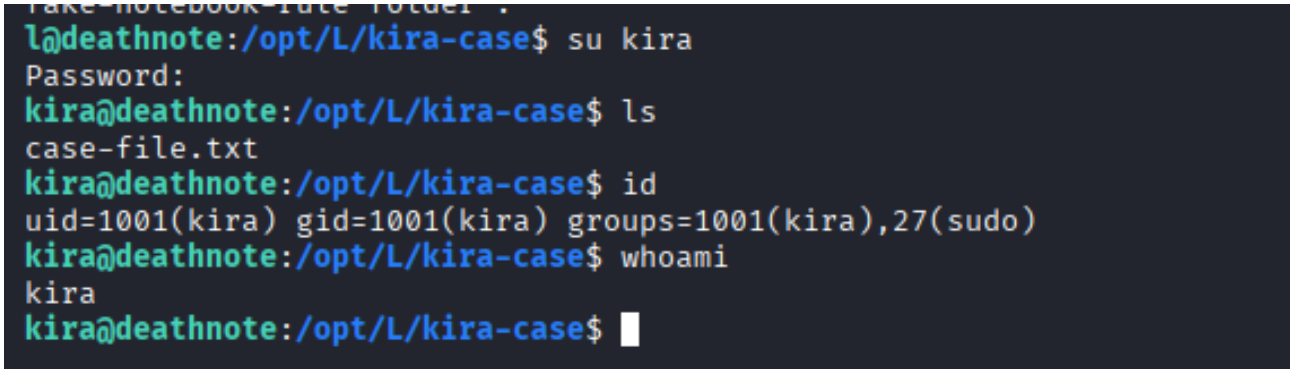
```
ssh kira@192.168.31.43
```

Steps: (1) Connect to the victim IP. (2) Authenticate using the credential recovered from the challenge clue. (3) Run `id` and `whoami` to validate the account context. Do not publish credentials in a public repository.

Observed result: The evidence shows a shell prompt for `kira@deathnote`, with `uid=1001(kira)` and `whoami` returning `kira`. This demonstrates credential-based SSH access, not an SSH service exploit.



Evidence 11. SSH session; unrelated previous-login address redacted.



Evidence 12. kira account and identity confirmation.

PoC 8 — Local privilege escalation through sudo misconfiguration

Objective: Determine whether the compromised account has excessive administrative permissions.

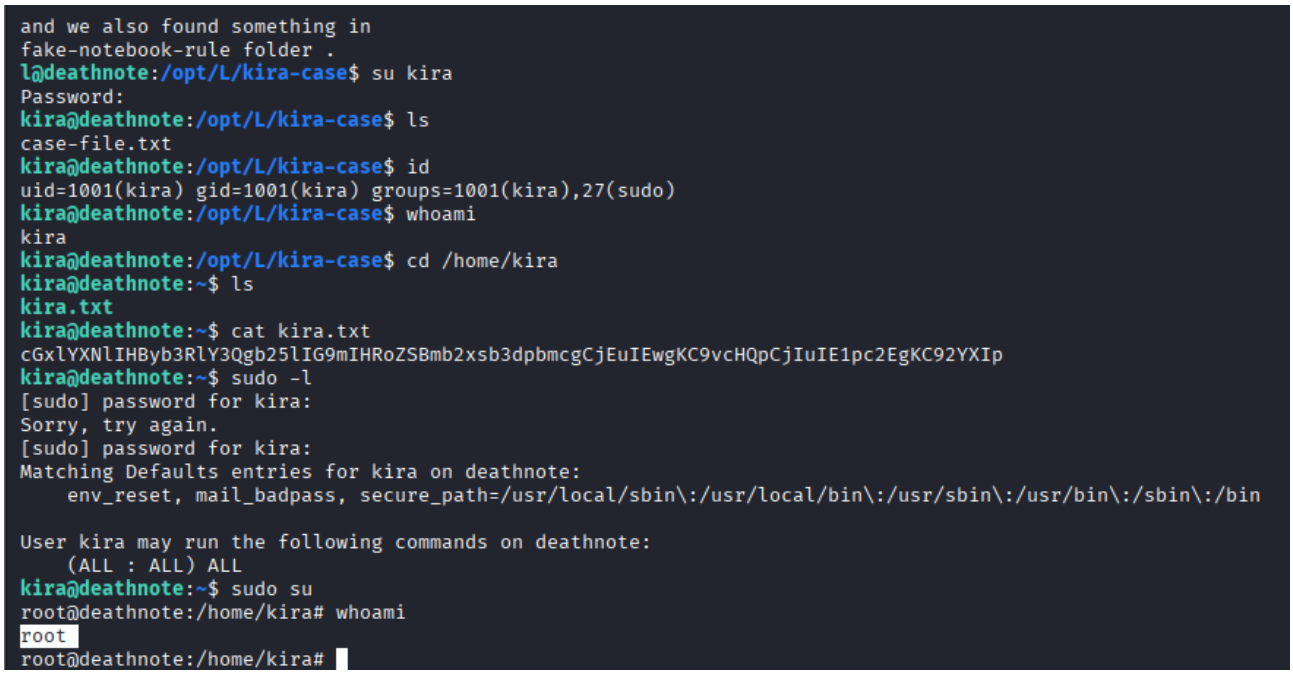
Commands shown in evidence:

```
sudo -l
sudo su
whoami
```

Steps: (1) As kira, run `sudo -l` to inspect allowed privileged commands. (2) The screenshot shows an unrestricted rule: `(ALL : ALL) ALL`. (3) The supplied evidence then shows `sudo su`. (4) Run `whoami` to confirm the resulting identity.

Observed result: `whoami` returns **root**. This confirms root-level compromise due to excessive sudo permissions and is the highest-confidence critical finding in the evidence.

Remediation: Remove the unrestricted sudo rule; grant only the minimum required commands; review sudoers using `visudo`; and audit members of privileged groups.



Evidence 13. sudo permission review and root shell.

PoC 9 — Validate the spreadsheet's FTP claim before reporting it

Objective: Resolve the discrepancy between the spreadsheet and Nmap evidence.

Validation command:

```
nmap -sV -p 21 192.168.31.43
```

Current evidence: The provided Nmap service scan shows ports 22 and 80 open and does not show FTP as open. The spreadsheet's “vsftpd 2.3.4 / Critical” entry is therefore not independently substantiated by the screenshots.

Reporting rule: If port 21 is closed, record the spreadsheet entry as not reproduced. If open, capture the service banner and validate the installed version and exposure before identifying a vulnerability. Do not claim exploitation without corresponding evidence.

PoC Summary and Evidence Matrix

PoC	Evidence / outcome	Status
1. Host discovery	Victim identified as 192.168.31.43	Confirmed
2. Service scan	22/tcp SSH; 80/tcp HTTP	Confirmed
3. WordPress source	WordPress 5.8 metadata observed	Confirmed
4. Dirsearch	Web paths enumerated	Confirmed
5. robots.txt clue	Clue points to important.jpg	Confirmed
6. Decode clue	Credential clue recovered	Confirmed
7. SSH login	kira session / identity shown	Confirmed
8. Sudo escalation	Unrestricted sudo; root identity shown	Confirmed
9. FTP port 21	Not open in supplied scan screenshot	Unverified

These detailed PoCs are based only on the screenshots supplied. They distinguish confirmed observations from items that require additional validation.